НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ «ОДЕСЬКА ЮРИДИЧНА АКАДЕМІЯ»

Факультет кібербезпеки · Кафедра інформаційних технологій

Лабораторна робота 6

Безпека та продуктивність системи

Варіант 12 · Управління автопарком та маршрутами

Черниченко Владислав · Коцюба Максим

FleetFlow · 27 жовтня 2026 року

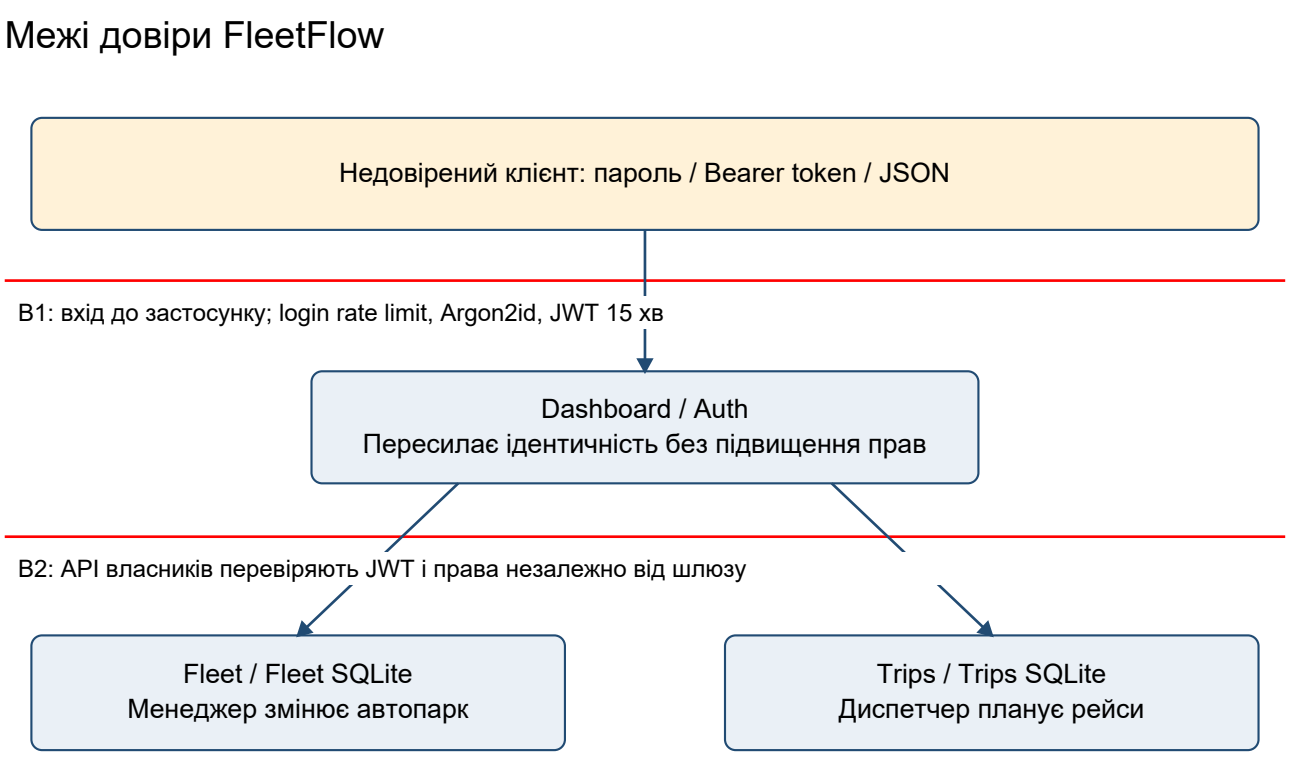
Мета та отриманий результат

До версії ЛР5 додано локальний вхід, JWT і перевірку прав у кожному сервісі. Для читання першої сторінки активних рейсів при 100 користувачах p95 зменшився з 8682.2 до 470.2 мс. Мета ЛР1 - не більше 500 мс - виконана в цьому короткому локальному експерименті. При 200 користувачах вона порушується.

Вихідні матеріали: lab1.docx–lab5.docx з Downloads, код C:\lab5 та методички ЛР1–8. Початкові файли не змінено. Нова версія відтворює ті самі контексти Fleet і Trips, незалежні SQLite, події та вебпанель.

Репозиторій попередніх робіт: https://github.com/VladyslavCh412/labs. Нові каталоги lab6–lab8 підготовлено локально; їх публікація та виконання GitHub Actions не заявляються.

1 Межі довіри



B3: процес - власна БД; B4: bridge - event API, окрема службова роль.

B1 передає логін і пароль або токен від недовіреного клієнта. B2 передає запит Dashboard до API власника; заголовок Authorization пересилається без підвищення прав. B3 відокремлює кожен процес від його власного SQLite. B4 передає outbox, подію та ACK між bridge і сервісами. Сервіси не довіряють самому факту локального походження запиту.

2 Модель загроз STRIDE

Межа та категорія	Загроза	Вплив / імовірність	Протидія
Вхід / Spoofing	Підбір пароля або чужий токен	Високий / середня	Argon2id; 10 спроб за хвилину на IP; JWT exp 15 хв, перевірка підпису, iss та aud.
Токен / Tampering	Зміна role або exp у JWT	Високий / середня	Фіксований алгоритм HS256; відхилення підробленого, простроченого й некоректного токена.
API / Elevation	Прямий PATCH Fleet в обхід Dashboard	Високий / висока	RBAC у Fleet; диспетчер і viewer отримують 403 навіть на порті 8101.
Event API / Tampering	Підроблена подія змінює проєкцію	Високий / середня	POST подій та ACK дозволені лише bridge; ідемпотентність event_id і монотонна version.
Журнал / Disclosure	Пароль або Bearer у журналі	Високий / середня	Журнал містить лише час, суб'єкт, шлях без query, метод, статус і результат.
Запити / Denial	Великий список рейсів виснажує CPU/RAM	Високий / висока	limit 1–100; SQL LIMIT/OFFSET; навантажувальний поріг; localhost стенд.
Аудит / Repudiation	Користувач заперечує зміну статусу	Середній / середня	Аудит відмов, входу та операцій зміни; локальний JSONL до відповіді клієнту.
БД / Tampering	SQL injection у параметрах	Високий / низька	Параметризовані SQL-запити; Pydantic; відсутність доступу до чужої БД.

Прийняті ризики

HTTP допустимий лише для стенду на 127.0.0.1. До зовнішнього розгортання потрібні TLS, IdP із асиметричними ключами, ротація та централізований аудит. HS256 означає взаємну довіру процесів: власник спільного ключа може випускати токени. Компрометація одного сервісу загрожує всім.

Вихід із вебпанелі видаляє токен із пам'яті браузера; вже викрадений токен дійсний до exp. Ротація, denylist, MFA й адміністрування ролей не реалізовані. Локальний JSONL не є захищеним від адміністратора ОС. Rate limit локальний, на один процес; бізнес API не має розподіленого rate limit.

3 Автентифікація та авторизація

setup_local.py генерує унікальний випадковий ключ і три випадкові паролі; users.json зберігає Argon2id-хеші. Файли з ключем, хешами та локальними паролями містяться тільки в ігнорованій data/. У переданих архівах їх немає. launch.py передає конфігурацію дочірнім процесам.

POST /auth/token приймає JSON username/password. JWT має sub, role, iss=fleetflow-local, aud=fleetflow-api, iat, exp та jti; exp = iat + 900 секунд. Кожен API перевіряє підпис і обов'язкові claims. Браузер тримає Bearer лише у пам'яті, не в localStorage.

Роль	Fleet як власник ресурсу	Trips як власник ресурсу
manager	Читання та зміна автопарку	Читання, створення рейсів і маршрутів
dispatcher	Лише читання	Читання, створення рейсів і маршрутів
viewer	Лише читання	Лише читання
trips-service	GET даних ТЗ та водіїв	Немає зовнішніх прав
bridge	Outbox / ACK	POST /events/fleet-status

Власник ресурсу тут означає сервіс, який володіє сутністю, відповідно до ЛР5. Поділ за організаціями або row-level ACL конкретного користувача не реалізований. Health і опис OpenAPI публічні; бізнес-дані захищені.

Перевірки test_security.py та live_smoke.py: відсутній / підроблений / прострочений JWT → 401; dispatcher напряму PATCH Fleet → 403; manager PATCH Fleet → 200; viewer POST route → 403; dispatcher POST

route → 201; manager POST внутрішньої події → 403; bridge → успіх. Аудит відмови записується до відповіді й не містить секретів.

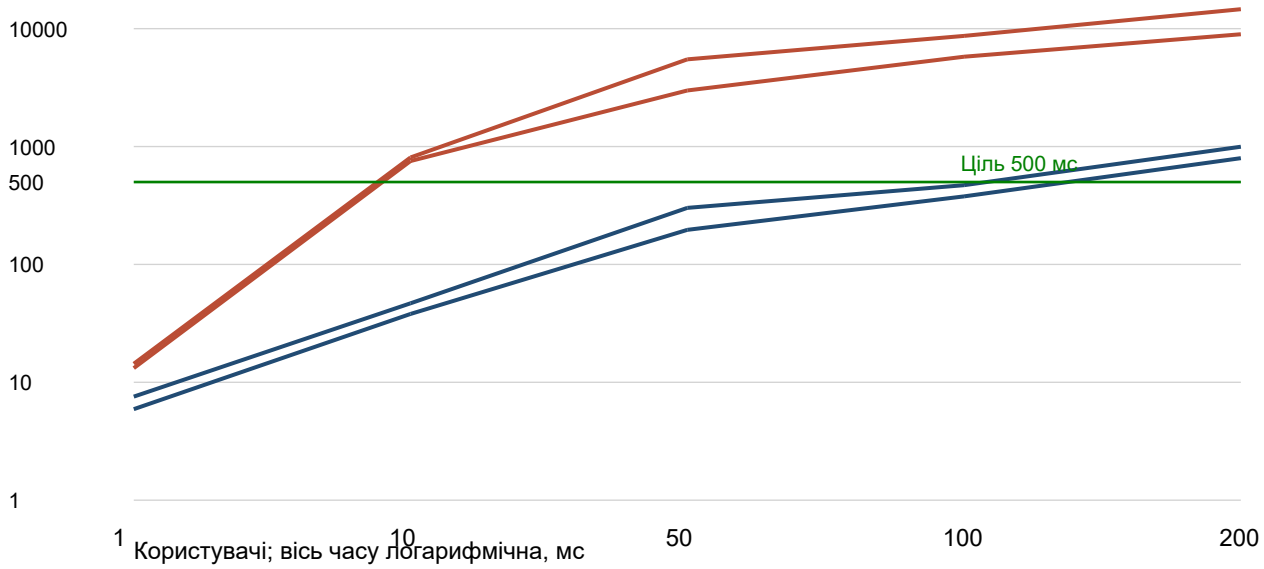
4 План навантажувального експерименту

Параметр	Умови
Сценарій	GET /trips?active=true&limit=50; перша сторінка з 50 planned/active рейсів; dispatcher JWT перевіряється на кожен запит.
Дані та середовище	5000 рейсів у тимчасовому SQLite; Windows-11-10.0.26200-SP0; Python 3.13.14; 12 логічних CPU; один процес Uvicorn; локальна мережа loopback.
Профіль	1, 10, 50, 100, 200 одночасних користувачів; closed-loop без think time; окремий постійний HTTP-клієнт на користувача.
Прогрів та тривалість	Один запит кожного користувача до початку вимірювання. Запуск запитів протягом 3 с; вже розпочаті запити очікуються, тому фактична тривалість етапу довша.
Показники	HTTP p50, p95, кількість запитів, частка помилок, throughput; repository p95 через Server-Timing. Percentile: nearest-rank.
Порівнянність	Той самий процесний код, дані, JWT, параметри, клієнт і профіль. TRIPS_READ_MODE перемикає baseline / optimized. Запуски послідовні.
Критерій	p95 ≤ 500 мс при 100 користувачах; відсутність помилок. Це локальний короткий тест, а не тривалий soak або випробування deployment.

5 Результати та вузьке місце

Users	p50 до	p95 до	p50 після	p95 після	Запити після	Помилки
1	13.2	14.4	5.9	7.6	496	0%
10	753.6	808.1	38.0	46.8	784	0%
50	2989.2	5491.4	196.4	301.7	720	0%
100	5781.7	8682.2	377.7	470.2	798	0%
200	8965.3	14625.5	797.0	996.3	819	0%

HTTP час відповіді до і після оптимізації



Червоний - до; синій - після; суцільна - p95, пунктир - p50.

Час наведено в мс. При 100 користувачах прискорення p95 становить 18.47 раза; repository p95 до оптимізації - 3136.6 мс, після - 52.7 мс. На baseline перший порушений виміряний рівень - 10 користувачів; після оптимізації - 200. Точний перегин між сусідніми рівнями не визначено.

Причина: trips() робив SELECT усіх рядків, матеріалізував усі dict та лише потім обрізав сторінку. При конкурентному виконанні зростали витрати декодування SQLite і Python та черга. Гіпотезу перевірено вимірюванням repository через Server-Timing.

Оптимізація: WHERE active, ORDER BY rowid DESC, параметризовані LIMIT/OFFSET на рівні SQLite; для вже сформованої проєкції - JSONResponse без повторного обходу FastAPI jsonable_encoder. test_pagination.py порівнює baseline і optimized для різних offset і фільтрів. Контракт повертає той самий JSON-масив; розмір сторінки обмежено 100.

Сирі дані: verification/load_results.json. Команда: python verification/load_test.py --duration 3 --rows 5000 --levels 1,10,50,100,200. CPU та RAM не вимірювалися окремим профайлером; висновок про ділянку базується на часу repository, а не на вигаданому розподілі CPU.

6 Відтворення та висновки

Розпакувати lab6, запустити СТАРТ_FleetFlow.bat. Він створює .venv, встановлює залежності й запускає Fleet, Trips, bridge та Dashboard. Вхід: http://127.0.0.1:8000; облікові дані з data/LOCAL_ACCOUNTS.txt після першого запуску. Альтернатива: python -m venv .venv; .venv\Scripts\python.exe -m pip install -r requirements-dev.txt; .venv\Scripts\python.exe launch.py.

Безпека та зв’язки перевірені через реальні HTTP-процеси у live_smoke.py з тимчасовими БД. Старі бізнес-перевірки збережено; у регресійних тестах змінено тільки передавання нових облікових даних. Додаткові негативні тести використовують звичайний TestClient без автоматичної авторизації.

Ролі для підготовки захисту: Владислав - відтворення навантаження та пояснення оптимізації; Максим - межі довіри, JWT і RBAC. Це розподіл матеріалів для захисту, а не підтвердження особистого виконання експериментів.

Сценарій читання 50 активних рейсів підтверджено при 100 користувачах на цьому стенді. Відмови доступу перевірені на обох власниках ресурсів. Зміна ролей, GPS, зовнішня маршрутизація, RTO/RPO та production-відмовостійкість залишаються непідтвердженими.

Джерела

Методичні вказівки ЛР6; lab1.docx–lab5.docx; вихідний код C:\lab5.

FastAPI Security: https://fastapi.tiangolo.com/tutorial/security/oauth2-jwt/ ; OWASP REST Security: https://cheatsheetseries.owasp.org/cheatsheets/REST_Security_Cheat_Sheet.html ; PyJWT: https://pyjwt.readthedocs.io/ .